



General Data Protection Regulation (GDPR) Implementation Guide

Contents

1	INTRODUCTION.....	2
1.1	THE VALUE OF LEGAL ADVICE.....	2
1.2	TRY TO THINK BIG ON DATA PROTECTION	2
2	A SUMMARY OF THE GENERAL DATA PROTECTION REGULATION.....	3
2.1	THE FORMAT OF THE REGULATION	3
2.2	DEFINITIONS	4
2.3	PRINCIPLES	4
2.4	LAWFULNESS	5
2.5	CONSENT	5
2.6	RIGHTS OF THE DATA SUBJECT	6
2.7	DATA PROTECTION OFFICER.....	7
2.8	CONTRACTS BETWEEN CONTROLLER AND PROCESSOR.....	7
2.9	PRIVACY BY DESIGN AND DATA PROTECTION IMPACT ASSESSMENTS	7
2.10	CODES OF CONDUCT AND CERTIFICATION.....	8
2.11	INTERNATIONAL TRANSFERS	8
2.12	SUPERVISORY AUTHORITIES	8
2.13	EUROPEAN DATA PROTECTION BOARD	9
2.14	REMEDIES, LIABILITY AND PENALTIES.....	9
2.15	WHERE TO FIND MORE OFFICIAL GUIDANCE ABOUT THE GDPR	9
3	THE CERTIKIT GDPR TOOLKIT	11
3.1	A WORD ABOUT VISIO.....	11
3.2	HOW THE DOCUMENTS WORK.....	11
3.3	IF YOU'RE MOVING FROM VERSION 4.....	12
3.4	LAST WORDS BEFORE YOU BEGIN	13
4	PREPARING FOR THE GDPR.....	14
4.1	STEP 1 - GDPR PREPARATION PROJECT	14
4.2	STEP 2 - GDPR ROLES, AWARENESS AND TRAINING	16
4.3	STEP 3 - PERSONAL DATA ANALYSIS.....	17
4.4	STEP 4 - PRIVACY POLICY AND NOTICES	19
4.5	STEP 5 - RIGHTS OF THE DATA SUBJECT	20
4.6	STEP 6 - CONTROLLERS AND PROCESSORS.....	21
4.7	STEP 7 - DATA PROTECTION IMPACT ASSESSMENT.....	22
4.8	STEP 8 - INTERNATIONAL TRANSFERS.....	22
4.9	STEP 9 - PERSONAL DATA BREACH MANAGEMENT.....	23
4.10	STEP 10 – INFORMATION SECURITY POLICIES.....	24
5	CONCLUSION.....	25
6	APPENDIX A – LIST OF SUPERVISORY AUTHORITIES.....	26

1 Introduction

The purpose of this guide is to help you to prepare your organisation for GDPR compliance using the CertiKit GDPR Toolkit. There are many different ways to approach the process of ensuring that your organisation meets the requirements of the GDPR and the method described here is simply one alternative. The GDPR is a complex piece of legislation with far-reaching implications and our aim in this guide is to present the main points (but we won't be covering *everything* – the Regulation is a long document) in an easily-understood format so that you can get started as soon as possible.

1.1 The value of legal advice

What we present here (and in the Toolkit) is our understanding of what's required for GDPR compliance, based on a lot of years in the IT and information security industry, analysis of the GDPR itself and a variety of further inputs from conferences, books, webinars, presentations, discussions and examinations on the subject. But the main points we would make before you begin reading are that we aren't lawyers, that there is no replacement for well-informed and qualified legal advice and that you should obtain this before taking key decisions and dedicating significant resources to specific tasks. And reading the GDPR itself isn't a bad idea, too.

1.2 Try to think big on data protection

We probably also ought to mention the relationship between compliance with the GDPR and the concept of an Information Security Management System, or ISMS. The GDPR doesn't mandate an ISMS (or Personal Information Management System, PIMS) such as that described by the international standard for information security, ISO/IEC 27001. But when it comes to satisfying your supervisory authority that you have taken the security of personal data seriously, having a recognised framework in place that ensures you set objectives, manage risk and review success, could go a long way. See the relevant section on our website for more details about our ISO/IEC 27001 Toolkit.

2 A Summary of the General Data Protection Regulation

The General Data Protection Regulation (GDPR) was approved by the European Commission (EC) on 27 April 2016 and became law from 25 May 2018. It replaces the previous EC legislation which dealt with data protection which was the Data Protection Directive of 1995. One of the major differences between the GDPR and the previous law is that the GDPR is a *Regulation* rather than a *Directive*. This means that it automatically became law in each of the countries that make up the European Union without each of these countries needing to create their own, individual laws (in contrast with the previous Directive where, in each of the member states, a separate Data Protection Act had to be passed by the relevant state legislative body to enact it).

Whilst the emphasis is often on the rights of the data subject when discussing the GDPR, it's important to remember that the EC is also trying to make it easier for organisations to share personal data and “oil the wheels” of business within the EU, so it's not as one-sided as often thought. However, there are a number of important things to realise about the GDPR before we get into the detail.

Firstly, it concerns the personal data of EU citizens, wherever that data is held. This means that if your organisation is not based in the European Union but has customers (or suppliers or other parties) within it whose data you hold, the GDPR applies to you.

Leading on from this, it means that if your organisation doesn't look after that data in the way the GDPR requires, your organisation may be subject to the penalties that the Regulation allows. These penalties are a step change from previous legislation and in serious cases, they are designed to hurt.

Thirdly, if you do experience a breach of personal data, you have no choice but to tell the relevant supervisory authority about it. There are some caveats on that which we will come to later, but keeping a serious data breach to yourself is no longer an option.

But the mainstay of what the GDPR is about is forcing organisations to take the protection of the personal data of EU citizens seriously.

2.1 The format of the Regulation

The GDPR document itself is eighty-eight pages long and consists of two main parts:

Recitals – 173 numbered paragraphs that lay out the principles and intentions of the Regulation; if you like, the background.

Articles – the 99 sections that set out the detail of the Regulation – this is the part that must be complied with. Note however, that a significant part of the GDPR is concerned with the internal workings of the various EU bodies and so the number of articles that an organisation needing to comply with the GDPR must worry about is much less than that 99 figure.

2.2 Definitions

The Regulation provides a definition of twenty-six of the relevant terms, including the following (GDPR Article 4 – Definitions):

(1) *‘personal data’ means any information relating to an identified or identifiable natural person (‘data subject’); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person;*

(2) *‘processing’ means any operation or set of operations which is performed on personal data or on sets of personal data, whether or not by automated means, such as collection, recording, organisation, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment or combination, restriction, erasure or destruction;*

(7) *‘controller’ means the natural or legal person, public authority, agency or other body which, alone or jointly with others, determines the purposes and means of the processing of personal data; where the purposes and means of such processing are determined by Union or Member State law, the controller or the specific criteria for its nomination may be provided for by Union or Member State law;*

(8) *‘processor’ means a natural or legal person, public authority, agency or other body which processes personal data on behalf of the controller;*

(11) *‘consent’ of the data subject means any freely given, specific, informed and unambiguous indication of the data subject’s wishes by which he or she, by a statement or by a clear affirmative action, signifies agreement to the processing of personal data relating to him or her;*

2.3 Principles

The GDPR establishes a number of principles that underpin the legislation and are outlined using the following terms (with our quick summary given after each):

1. *Lawfulness, fairness and transparency* – keep it legal and fair; say what you’re going to do with the data in clear terms
2. *Purpose limitation* – don’t do more with the data than you said you would
3. *Data minimisation* – don’t collect more data than you need
4. *Accuracy* – keep it up to date and deal with inaccuracies as soon as possible
5. *Storage limitation* – don’t keep the data for longer than necessary
6. *Integrity and confidentiality* – keep the data safe while you have them
7. *Accountability* – be able to show that you’re complying with the principles above

If you keep these principles in mind at all times, you're unlikely to fall foul of the GDPR.

2.4 Lawfulness

For the processing of personal data to be lawful, it must meet at least one of a number of criteria, and an important first step in considering your processing activities is to clearly establish which of the criteria applies in any given situation.

In essence, the criteria to choose from with regard to the lawfulness of the processing are as follows:

1. The data subject has **consented** to it
2. It's needed to perform a **contract** between your organisation and the data subject, or to see whether a contract can happen
3. You **legally** have to do it
4. You're protecting the **vital interests** of the data subject
5. It's in the **public interest**
6. It's for your **legitimate interests** – as long as it doesn't affect the data subject's rights and freedoms

So, whilst consent is an important aspect of the GDPR, it's not the only way in which collecting and processing personal data can be lawful. In fact, you may find that a significant proportion of the personal data your organisation holds and processes doesn't require consent; instead it is required for lawful purposes such as providing support to customers (contractual), paying employees (contractual/legal) or dealing with the tax authority (legal). The process of obtaining and maintaining consent may involve changes to business processes and systems so it is a good idea to make sure there is no other lawful basis on which processing can take place first.

In many cases it may be prudent to go for legitimate interest as the lawful basis for processing; if you choose to go down this route you will need to carry out a legitimate interest assessment which shows that you have considered all the angles.

2.5 Consent

If you believe that your processing is lawful because you have the data subject's consent, then you must be able to prove it. You can't hide the consent wording in amongst other contractual ramblings and expect to get away with it either. It must be in an *"intelligible and easily-accessible form, in clear and plain language"* (GDPR Article 7, paragraph 2) otherwise the consent doesn't count and your processing could be judged to be unlawful.

Once given, the consent can be withdrawn at any time by the data subject and this must be as easy to do as it was to give it in the first place. A child must be at least sixteen years of age to be able to

give consent (younger if a member state decides so, with a lower limit of thirteen) otherwise parental consent must be obtained.

2.6 Rights of the data subject

The GDPR establishes a set of rights that the data subject can exercise and which the controller holding their personal data must react and respond to, generally within a month.

- | | | |
|----|---|---|
| 1. | The right to be informed | being told what data will be collected, why, by whom, for what purpose and where the data will go |
| 2. | The right of access | being able to see personal data that are being held about the data subject |
| 3. | The right to rectification | getting the data corrected if they are wrong or inaccurate |
| 4. | The right to erasure | having personal data removed when they are no longer necessary |
| 5. | The right to restrict processing | pausing the processing of the data if there are grounds to do so |
| 6. | The right to data portability | obtaining the data in a transportable form and moving it to an alternative processor |
| 7. | The right to object | stopping the data from being processed |
| 8. | Automated decision making and profiling | having a human involved in important decisions |

These rights follow on from the principles that we discussed earlier and are aimed at ensuring that personal data are processed fairly and transparently and that the data subject can do something about it if this doesn't happen.

The data subject must be informed of their rights, along with a variety of other information about what their information will be used for and why, when the personal data are collected (or within a month if the data come from another source). This increased granularity of information means that a layered approach to privacy notices, with the relevant information being displayed "just in time" when the personal data are collected, may be preferable to the more traditional single privacy policy seen on many websites.

2.7 Data protection officer

Depending on your organisation and what it does with personal data, you may or may not need a data protection officer. You will have to designate one if:

- You're a public authority or body
- You monitor data subjects on a large scale
- Large volumes of special category data are involved

Data protection officers may be part-time, may be shared across organisations and may be external resources or services. They must remain independent and their contact details must be freely available, especially to data subjects. The data protection officer is the main contact with the supervisory authority and is likely to get involved when key issues of data privacy and protection are addressed within the organisation, such as during data protection impact assessments. The data protection officer will need to know a reasonable amount about data protection law in order to fulfil the role (but there's no "official" qualification that is required).

2.8 Contracts between controller and processor

The GDPR is very specific that it wants to see a contract in place between data controllers and processors that protects personal data and it defines the areas that this should cover. Basically this involves detailing the purpose and duration of the processing, the personal data categories involved and the data subjects it affects. The processor has to contractually commit to a set of minimum terms related to data protection and existing contracts will need to be changed to include them.

What we're seeing from the big players such as Google, Amazon Web Services and Microsoft is that they will make a pre-signed Data Processing Addendum to their current terms and conditions available to their customers, which in principle may save everyone a lot of time.

2.9 Privacy by design and data protection impact assessments

In order to establish a culture where data privacy is "baked in" to new processes and systems, rather than added as an after-thought, the GDPR requires that data protection impact assessments be carried out where the risks involved to data subjects are reasonably felt to be high. This process involves understanding the personal data involved and addressing likely risks through the use of appropriate controls, so that proactivity, rather than reactivity, is the order of the day.

2.10 Codes of conduct and certification

The regulation makes provision for member states, industry bodies and other organisations to create relevant codes of conduct and certification schemes that can be used to encourage and demonstrate compliance. It's early days for such schemes, but they are likely to increase in popularity and availability as time goes by, so it's well worth keeping an eye on what's happening in your country and industry.

2.11 International transfers

Sending the personal data of European citizens outside of the European Union raises questions over how well the data will be protected and the GDPR places restrictions on how this may be done. To be helpful, the European Commission regularly decides which countries it trusts to look after EU personal data and publishes a list of those deemed to be acceptable (called an "Adequacy Decision"). Currently, it's a small list so you may need to look at the other ways to meet the GDPR if you need to do international transfers.

Other ways to get approval are:

- A legally binding agreement (public bodies only)
- Binding corporate rules
- Using standard clauses in your contract
- Signing up to an approved code of conduct or certification scheme

If you're going to use binding corporate rules, be aware that they have to be approved by the relevant supervisory authority and that can take a while. There are a few get-outs (or "*Derogations*" as the GDPR calls them) for small, infrequent transfers so it may be worth checking the list in Article 49 if time is not on your side.

2.12 Supervisory authorities

Each country within the EU has a supervisory authority which is responsible for overseeing the operation of the GDPR in that country. However, if your organisation is outside of the EU but wishes to process the data of EU citizens in several countries, you will need to choose the most appropriate supervisory authority to act as the lead for your organisation. A list of supervisory authorities by country can be found at Appendix A.

2.13 European data protection board

The GDPR establishes the European Data Protection Board to oversee the application of the Regulation in the member states. Each supervisory authority has a seat on the Board, together with the head of the European Data Protection Supervisor. The Board will produce an annual report to tell us how well it's going.

2.14 Remedies, liability and penalties

And so we come to the teeth of the Regulation; the fines that can be levied for non-compliance with the GDPR are certainly larger than those for the Directive it replaces. The actual amounts demanded will depend upon a wide variety of factors, including the personal data involved, how hard the culprit organisation tried to protect the data, how much they co-operated with the investigation and, most importantly, the specific article(s) of the GDPR they are judged to have contravened.

Fines allowable are up to 2% of global turnover or ten million euros for lower level infringements and up to 4% of global turnover or twenty million euros for more serious cases.

Data subjects can lodge a complaint with the relevant supervisory authority directly themselves or may use the services of a not-for-profit body active in the field of data protection.

2.15 Where to find more official guidance about the GDPR

As with any new piece of legislation, the GDPR has room for interpretation and is full of terms like “high risk” and “large scale” that might be considered relative at best. Fortunately, this is where a forum called the European Data Protection Board (EDPB - formerly called the *Article 29 Working Party*) comes to the rescue, partially at least. This is effectively a committee, consisting of representatives of each of the supervisory authorities within the EU, that meets on a regular basis to thrash out some guidance on what the GDPR means. The EDPB produces guidance documents on specific aspects of the GDPR and publishes them on its website, free of charge. So far, they have turned their attention to a variety of areas including the following:

- Automated processing and profiling
- Breach notification
- Consent
- Administrative fines
- Data protection impact assessments
- Data protection officers
- Lead supervisory authorities
- The right to data portability
- Transparency

So if you find yourself struggling with how the GDPR applies to your organisation, try doing an Internet search for “GDPR EDPB” or “Article 29 working party” and you should end up on the relevant site.

The other place to visit is the website of your country’s supervisory authority (see Appendix A for a list), which likely has a wealth of guides and FAQs about the GDPR, including in some cases, a telephone helpline for those that have reached the stage that they really need to speak to a human.

3 The CertiKit GDPR Toolkit

Relevant Toolkit documents

- *CERTIKIT – GDPR Implementation Guide*
- *CERTIKIT - Standard Licence Terms*
- *CERTIKIT GDPR Toolkit V5 Completion Instructions*
- *CERTIKIT GDPR Toolkit Version 5 Release Notes*
- *EU General Data Protection Regulation 2016*

The CertiKit GDPR Toolkit (referred to within this document simply as “the Toolkit”) provides an array of useful documents which provide a starting point for the different areas of the Regulation. The documents are in Microsoft Office 2010® format and consist of Word documents, Excel workbooks, PowerPoint presentations, Visio diagrams and Project plans.

To open and edit the documents you will need to use the relevant Microsoft application at version 2010 or later. For the Microsoft Project file, we have provided the same content in an Excel spreadsheet also, for people who don’t use Microsoft Project.

3.1 A word about Visio

For Microsoft Visio files, you will be able to view them using Microsoft Internet Explorer or Edge. However, to edit the Visio files you will need a copy of Microsoft Visio 2010 or later. In the Toolkit We have provided versions of the Visio files in Word format too, for those people who don’t use Microsoft Visio. There is one file that is an exception to this - *GDPR-FORM-03-3 Personal Data Analysis Diagram*. That file doesn’t have a Word equivalent because it uses features of Visio that just aren’t available in Word, but are very useful when drawing pictures of your personal data and how it flows through your organisation. However, all of the information that is used in this Visio file is also included in the Excel file *GDPR-FORM-03-2 Personal Data Analysis Form*, so non-Visio users won’t miss out. Our recommendation would be to get yourself a copy of Microsoft Visio because it’s simply a great tool for drawing diagrams, and if you buy an older version, such as 2010, it doesn’t cost that much either. But rest assured, you can still capture all the required information about your personal data without it.

3.2 How the documents work

The documents themselves have a common layout and look and feel and adopt the same conventions for attributes such as page widths, fonts, headings, version information, headers and footers. Custom fields are used for the common items of information that need to be tailored such

as [Organization Name] and these are easily changed in the document properties (see *CERTIKIT GDPR Toolkit V5 Completion Instructions* for details of how to do this).

Each document starts with an “Implementation Guidance” section which describes its purpose, the specific chapters or articles of the GDPR it is relevant to, general guidance about completing and reviewing it and some legal wording about licensing etc. Once read, this section, together with the CertiKit cover page, may be removed from the final version of the document.

The layout and headings of each document have been designed to guide you carefully towards meeting the requirements of the Regulation and example content has been provided to illustrate the type of information that should be given in the relevant place. This content is based upon an understanding of what a “typical” organisation might want to say but it is very likely that your organisation will vary from this profile in some ways, so you will need to think carefully about what content to keep and what to change. The key to using the Toolkit successfully is to review and update each document in the context of your specific organisation. Don’t accept the contents without reading them and thinking about whether they meet your needs – does the document say what you want it to say, or do you need to change various aspects to make it match the way you do things? This is particularly relevant for policies and procedures where there is no “right” answer. The function of the document content is help you to assess what’s right for you so use due care when considering it. Where the content is very likely to need to be amended we have highlighted these sections but please be aware that other non-highlighted sections may also make sense for you to update for your organisation.

3.3 If you’re moving from version 4

The GDPR Toolkit Guidance folder of the Toolkit includes the document *CERTIKIT GDPR Toolkit Version 5 Release Notes* which tells you what has changed in each document if you are currently working with Version 4. The main changes are:

- Updating to reflect the fact that the GDPR is now applicable, rather than simply impending legislation
- The addition of a CCTV Policy and supporting Privacy Notice
- An example Data Protection Impact Assessment to give you a better idea of how the DPIA process works
- A sub-processor agreement to allow a processor to legally appoint sub-processors to help out
- Additions to the Personal Data Analysis Form to capture the exclusions that might allow the processing of special category personal data
- A poster to publish within your organisation to encourage greater awareness of data protection issues
- Various technical and formatting tweaks and fault fixes

We’ve had a fantastic amount of useful feedback from version 4 users and we hope we’ve done justice to the ideas they gave us to make the Toolkit better.

3.4 Last words before you begin

The remainder of this guide will take you through what you may need to do in each area and show how the various items in the CertiKit GDPR Toolkit will help you to meet the requirements quickly and effectively.

As we've said earlier, regard this guide as helpful advice rather than as a detailed set of instructions to be followed without thought; every organisation is different and the idea of the Toolkit is that it moulds itself over time to fit your specific needs and priorities.

We also appreciate that you may be limited for time and so we have kept the guidance short and to the point, covering only what we think you might need to know to achieve compliance. There are many great books available on the subject of the GDPR and information security generally and we recommend that, if you have time, you invest in a few and supplement your knowledge as much as possible.

But perhaps our single most important piece of advice would be to read the GDPR itself. We know you don't want to because, let's be honest, in places it's a bit boring. But there's really no replacement for going straight to the source document if you want to understand what it's all about. So by all means, listen to what other people tell you about it, but try to take some time out to go to a coffee shop or somewhere equally comfortable, and read the thing from beginning to end (or at the very least, the relevant Articles). We believe you won't regret it. Enough said.

4 Preparing for the GDPR

Given that data protection is not a new concept and the GDPR follows on from a Directive that has been in place for over twenty years, it is unlikely that you will be starting from nothing when working towards compliance with the new Regulation (unless of course, you're a new start-up). This means that the emphasis will be more on improving what you already have and filling the gaps in those areas where the GDPR introduces something new. But many will see this as an opportunity for a major review and possibly overhaul of the way that they collect, hold and process personal data; a chance to get better acquainted with how their business works and build some extra benefit into what is otherwise a straightforward need to comply. That's possibly where the real value of the GDPR lies.

This section gives guidance about what to consider when approaching the GDPR, in the approximate order in which the steps might be approached (although this does depend on where you're starting from). The sections correspond to the folders within the Toolkit and explain how each of the documents within that folder may be used, and the key tasks involved in each step are listed.

4.1 STEP 1 - GDPR preparation project

Relevant Toolkit documents

- *GDPR-DOC-01-1 GDPR Compliance Project Initiation Document*
- *GDPR-DOC-01-2 GDPR Preparation Project Plan (Microsoft Project Version)*
- *GDPR-DOC-01-3 GDPR Preparation Project Plan (Microsoft Excel Version)*
- *GDPR-DOC-01-4 GDPR Documentation Log*
- *GDPR-DOC-01-5 GDPR Briefing Presentation*
- *GDPR-DOC-01-6 Executive Support Letter*
- *GDPR-FORM-01-1 Compliance Evidence*
- *GDPR-FORM-01-2 Meeting Minutes*
- *GDPR-FORM-01-3 GDPR Gap Assessment Tool*

Key tasks

- Perform a gap assessment
- Get senior management behind you
- Define, plan and initiate your project
- Get your GDPR documentation organised

The first step to complying with the GDPR is to understand how much of it your organisation already does anyway. In order to quantify how much additional work may be involved in getting to full compliance with the Regulation, a *GDPR Gap Assessment Tool* is provided within the Toolkit. This summarises the key points of the relevant sections of the Regulation in question form and is intended to give you a reasonable idea of where your compliant and non-compliant areas are.

Roughly two thirds of the articles in the GDPR are aimed at bodies other than an organisation trying to comply so they aren't really requirements that you will need to worry about; these cover tasks such as the setting up of the European Data Protection Board, certification schemes and the rules that the supervisory authorities in each member state must follow.

The accompanying workbook *Compliance Evidence* shows you how the various documents in the Toolkit map onto the requirements and what other evidence may be appropriate to show compliance. This may help when deciding whether a requirement is met or not.

We recommend you manage your compliance journey as a project, and one of your first tasks will be to secure the commitment of senior management. This is probably the single most significant factor in whether such a project (and the ongoing operation of the implemented processes afterwards) will be successful.

The first questions senior management are likely to ask about the GDPR and the proposed project are probably:

- What are the requirements we must meet?
- How much will it cost?
- When does it have to be in place by?

An introductory presentation is included in the Toolkit to use when communicating the main points about the GDPR to management. Probably the most important points are that compliance is not optional, it's already law, and the potential fines are big.

Senior management support for the project may be demonstrated by publishing a letter/memo similar to the *Executive Support Letter* in the Toolkit.

Having secured management commitment, you will now need to plan how to achieve GDPR compliance. Even if you're not using a formal project management method such as PRINCE2® we would still recommend that you do the bare essentials of project management in defining, planning and tracking the implementation effort.

We have provided a template *Project Initiation Document* (or PID) which prompts you to define what you're trying to achieve, who is involved, timescales, budget, progress reporting etc. so that everyone is clear from the outset about the scope and management of the project. This is also useful towards the end of the project when you come to review whether the project was a success.

Having written the PID, try to ensure it is formally signed off by senior management and that copies of it are made available to everyone involved in the project so that a common understanding exists in all areas.

The CertiKit GDPR Toolkit also provides a Microsoft Project® plan as a starting point for your project (reproduced in Excel for non-Project users). This is fairly high level as the detail will be specific to your organisation but it gives a good indication as to the rough order that the project should be approached in.

Lastly, we suggest you keep track of your GDPR-relevant documentation using the *GDPR Documentation Log*, and that you get into the habit of minuting relevant meetings, even at a basic level – see the template for this in the Toolkit.

4.2 STEP 2 - GDPR roles, awareness and training

Relevant Toolkit documents

- *GDPR-DOC-02-1 GDPR Roles and Responsibilities*
- *GDPR-DOC-02-2 GDPR Competence Development Procedure*
- *GDPR-DOC-02-3 GDPR Communication Programme*
- *GDPR-DOC-02-4 Information Security Awareness Training*
- *GDPR-DOC-02-5 GDPR Awareness Training Presentation*
- *GDPR-FORM-02-1 GDPR Competence Development Questionnaire*
- *GDPR Awareness Poster (for data subjects)*
- *GDPR Awareness Poster (for employees)*

Key tasks

- Communicate and promote awareness about GDPR
- Define roles and who will fill them
- Nominate your supervisory authority
- Decide if you need a data protection officer
- Identify training needs and address them

Once you've initiated your project and defined who will perform which role, there is a lot of value in raising general awareness about the GDPR and information security in general so that people know what it is and why it's important. Audiences will include various stakeholders such as suppliers and contractors as well as employees and it's useful to create a managed programme of communication so that it happens regularly. The Toolkit provides a template for a *GDPR Communication Programme* and some presentation slides for GDPR and *Information Security Awareness Training*. Some basic awareness posters are also provided which may be used either electronically or simply put on the wall everywhere where personal data is processed.

It's important to establish from the start who is going to do what, both within your initial project to comply with the GDPR, and for the long-term protection of the personal data that you hold. The *GDPR Roles and Responsibilities* document sets out various roles, including those of controller and processor (if required), data protection officer and an information security manager. If not already allocated, decisions need to be taken about who will fulfil these roles, including potential recruitment.

The only role that is explicitly mandated in the GDPR is that of the data protection officer (DPO). You may or may not need to appoint one of these. If you're a public body there's no decision to be made (you need one), but otherwise you may need to get views from different perspectives within the business about whether you handle personal data on a scale that might be considered large. Your supervisory authority may be able to advise, either directly or via their website, if you're unsure about this.

If you do need a DPO, you'll need to decide whether to appoint internally, share a resource with one or more similar organisations, or to contract a service from a third party. Make sure the person that is appointed has the relevant competence, including *"expert knowledge of data protection law and practices"* (GDPR Article 37, paragraph 5).

One of the other points you may need to clarify is the supervisory authority that you will report into. For single-country organisations within the EU this should be a straightforward matter, but if your organisation is based outside the EU or you operate across borders within the EU, there is a decision to be made about who will be your representative and hence determine your lead supervisory authority. Remember that you will need to be able to justify this choice, based mainly on where you do business the most, but there may be some flexibility if you have a preference.

You also need to identify the training needs of the people that are taking on the various roles involved in achieving compliance on an ongoing basis. This may be done by defining what competences are required (use *GDPR Competence Development Procedure*) and then conducting a comparison exercise by questionnaire to find the gaps (use *GDPR Competence Development Questionnaire*); these may be filled via a combination of formal and informal training, including courses, webinars, seminars, books and, of course, reading the Regulation itself. Training may typically be needed in areas such as data analysis, data protection impact assessments and incident management.

4.3 STEP 3 - Personal data analysis

Relevant Toolkit documents

- *GDPR-DOC-03-1 Personal Data Analysis Procedure*
- *GDPR-DOC-03-2 Legitimate Interest Assessment Procedure*
- *GDPR-FORM-03-1 Records of Processing Activities*
- *GDPR-FORM-03-2 Personal Data Analysis Form*
- *GDPR-FORM-03-3 Personal Data Analysis Diagram - VISIO*
- *GDPR-FORM-03-4 Personal Data – Initial Questionnaire*
- *GDPR-FORM-03-5 Legitimate Interest Assessment Form*
- *EXAMPLE Personal Data Analysis Form*
- *EXAMPLE Personal Data Analysis Diagram - VISIO*

Key tasks

- Discover and record your use of personal data
- Identify and justify the lawful basis of each processing activity
- Start keeping records of your processing

Once your people are in place and they've received some training, the next step is to do some analysis of the way in which personal data are currently collected, stored, processed, transferred and disposed of within your organisation. There are many ways to represent this analysis but most come down to drawing diagrams of the flow and recording the relevant information on a spreadsheet (see *Personal Data Analysis Procedure*). You'll need to involve the people who are responsible for collecting and processing the data on a daily basis to ensure that as full a picture as possible is obtained. You could do this by sending out an initial fact-finding questionnaire (use *Personal Data – Initial Questionnaire*), followed by arranging workshops and using whiteboards and sticky notes, or you could simply send them a more detailed spreadsheet (use *Personal Data Analysis Form*) straight away and ask them to complete it, or you could do both; whatever fits the culture of your organisation.

What's key here is to understand the main facts such as the data items that are being collected, for what purpose, by what method (e.g. on the website, face to face, paper form), where, how and for how long the data are stored and where they get sent to. This will help in identifying any additional controls that need to be applied to them (such as encryption) and in establishing the legal basis under which they may be collected and processed (e.g. consent, contractual, legitimate interest). If you're going to rely on legitimate interest for some of your processing then you'll need to conduct a reasonable assessment of how your interests balance out against those of the data subject, and the Toolkit provides a procedure and an assessment form for that purpose.

The Toolkit provides further help with a template for a *Personal Data Analysis Diagram* if you prefer to use a diagrammatic representation of your data (requires Microsoft Visio, an example of what such a diagram might look like is provided). All of these tools are intended to help you gain a full and accurate appreciation of your organisation's use of personal data.

The GDPR requires that you keep records of the processing activities your organisation performs, both as a controller and as a processor on behalf of other controllers. The Toolkit document *Records of Processing Activities* prompts for the information required, and it should become clearer, as you investigate your use of personal data, what should be recorded in it.

Your supervisory authority could at any time ask to see the records of the processing of personal data that you carry out, so it's a good idea to be clear from the outset about where this information is to be found. As well as keeping a spreadsheet of the main items of information, you also need to be aware of the records such as logs and audit trails that exist at a lower level, reflecting the detail of what was done when.

The full picture for GDPR purposes will consist of a wide variety of items such as data protection impact assessments, privacy notices, subject request registers, data mappings and risk assessments, which together reflect how seriously the protection of personal data is being taken within the

organisation. This will become particularly important in the event of a data breach when the supervisory authority comes to decide the level of penalty that might be appropriate.

4.4 STEP 4 - Privacy policy and notices

Relevant Toolkit documents

- *GDPR-DOC-04-1 Records Retention and Protection Policy*
- *GDPR-DOC-04-2 Data Protection Policy*
- *GDPR-DOC-04-3 Privacy Notice Procedure*
- *GDPR-DOC-04-4 Website Privacy Policy*
- *GDPR-DOC-04-5 CCTV Policy*
- *GDPR-FORM-04-1 Privacy Notice Planning Form – Data Subject*
- *GDPR-FORM-04-2 Consent Request Form*
- *GDPR-FORM-04-3 Privacy Notice Planning Form – Other Source*
- *EXAMPLE Privacy Notice - Newsletter Signup*
- *EXAMPLE Privacy Notice - Online Purchase*
- *EXAMPLE Consent Request Form*
- *EXAMPLE Privacy Notice – Employment*
- *EXAMPLE Privacy Notice - Website Enquiry*
- *EXAMPLE Website Privacy Policy*
- *EXAMPLE Privacy Notice - CCTV*

Key tasks

- Define your policy on privacy, data protection and retention
- Create or update your privacy notices
- Plan to obtain consent where required

You'll need to define the organisation's overall policy on privacy and data protection, and also on how long you retain personal data for, taking into account the GDPR's requirement that you keep them no longer than is necessary for the purpose of the processing.

You will also need to create, and then consider the best way to communicate, your privacy notices to the data subject, making sure that they cover the information required by the GDPR. The Toolkit provides a procedure and a planning form for this purpose, along with a number of examples. Again, the best ways to do this will depend upon how you interact with your data subjects e.g. via the Internet, telephone, face to face. Privacy notices ideally need to be specific to the data being collected and the purpose, so a just in time approach, in which only the information relevant to the current transaction or screen is shown, may be preferable to a single, all-encompassing privacy

notice. However, we do provide a template for a layered website privacy policy, together with an accompanying example.

Collection of personal data which is based on consent needs particular thought, both in the way it is requested and in how it is held and processed. Don't rely on consent as a lawful basis of processing if a withdrawal of consent would mess up your business process and corrupt the integrity of your database. We provide a consent request form which, although it is based on a paper request, could also provide the basis for a consent request via other means, such as on a website.

4.5 STEP 5 - Rights of the data subject

Relevant Toolkit documents

- *GDPR-DOC-05-1 Data Subject Request Procedure*
- *GDPR-DOC-05-2 Data Subject Request Register*
- *GDPR-FORM-05-1 Data Subject Request Form*

Key tasks

- Define how data subject requests will be handled
- Put procedures in place to process them
- Start to record data subject requests

Making sure you allow the rights of the data subject to be exercised without hindrance is an important factor in GDPR compliance, and one which may attract the attention of the supervisory authority if not done properly. Although we provide a form within the Toolkit (*Data Subject Request Form*), the most effective way to allow the data subject to access and maintain their personal data is likely to be via some form of portal that the user can log in to via the Internet and do it directly themselves. Similarly, standard forms may be provided via such a portal for requests such as objections and processing restrictions. You will need to make sure you have the appropriate workflow behind the forms to ensure they are logged correctly, processed by the right people within the required timescales and that the identity of the requester is confirmed. Some requests will require decisions to be made and sometimes these will not be straightforward, so having a clear process and roles will be important – see the *Data Subject Request Procedure* in the Toolkit.

The *Data Subject Request Register* provides a way to log requests and track them through to completion according to the procedure.

4.6 STEP 6 - Controllers and processors

Relevant Toolkit documents

- *GDPR-DOC-06-1 GDPR Controller-Processor Agreement Policy*
- *GDPR-DOC-06-2 Processor GDPR Assessment Procedure*
- *GDPR-DOC-06-3 Processor Security Controls*
- *GDPR-DOC-06-4 GDPR Readiness Statement*
- *GDPR-DOC-06-5 GDPR Letter to Processors*
- *GDPR-FORM-06-1 GDPR Contract Review Tool*
- *GDPR-FORM-06-2 Processor GDPR Assessment*
- *GDPR-FORM-06-3 Processor Employee Confidentiality Agreement*
- *GDPR-FORM-06-4 GDPR Readiness Checklist*
- *GDPR-FORM-06-5 Data Processing Agreement*
- *GDPR-FORM-06-6 Sub-Processor Agreement*

Key tasks

- Update your contracts to be GDPR compliant
- Find out how your processors are protecting personal data
- If you're a processor, tell your controllers how you protect personal data
- Ensure confidentiality from your employees

The GDPR is very specific about the fact that there has to be a contract in place between a controller and a processor (and between a processor and a sub-processor) and about the information and terms that must be included in such a contract. These are laid out in the *GDPR Controller-Processor Agreement Policy* which, together with the template *Data Processing Agreement and Sub-Processor Agreement*, may be used as the basis of additional clauses in your relevant contracts, followed by some qualified legal review. Keep track of which contracts have been reviewed or need amendment using the *GDPR Contract Review Tool*.

The *Processor GDPR Assessment Procedure* and accompanying form may be used to fill in the gaps in your knowledge of how your suppliers store, process and protect the personal data you are the controller for, whilst the *GDPR Letter to Processors* is intended to help confirm how ready your processors actually are.

Where your organisation acts as a processor for other controllers, you will need to provide information about how your organisation protects their personal data, and the document *Processor Security Controls* can act as a starting point for your response. You will also need to be able to show that your employees who have access to personal data are bound by a confidentiality obligation. This may be achieved via existing employment contracts, but if not, a *Processor Employee Confidentiality Agreement* is provided to be used to gain that assurance from your employees.

If you need to declare your state of GDPR readiness to interested parties such as customers, a combination of the *GDPR Readiness Checklist* and the *GDPR Readiness Statement* may come in useful.

4.7 STEP 7 - Data protection impact assessment

Relevant Toolkit documents

- *GDPR-DOC-07-1 Data Protection Impact Assessment Process*
- *GDPR-DOC-07-2 Data Protection Impact Assessment Report*
- *GDPR-FORM-07-1 Data Protection Impact Assessment Tool*
- *GDPR-FORM-07-2 Data Protection Impact Assessment Questionnaire*
- *EXAMPLE Data Protection Impact Assessment*

Key tasks

- Plan how you will conduct data protection impact assessments
- Start to conduct them where appropriate

This is a relatively new area for many organisations, but one which is clearly mandated by the GDPR. New projects and significant changes to existing processes will need to carefully consider the potential impact on data subjects as part of their assessment and planning, with appropriate controls put in place, based on a fair assessment of the risk to the data subjects' rights and freedoms.

If you have a projects process, then this will need to be added to it; the GDPR states that this is necessary only where there is a high risk, but you may find that it is a good idea to perform these assessments as a matter of course for every project. Remember that you're assessing the risks to the data subjects, not to the organisation.

A process and supporting documents is provided as part of the Toolkit.

4.8 STEP 8 - International transfers

Relevant Toolkit documents

- *GDPR-DOC-08-1 Procedure for International Transfers of Personal Data*

Key tasks

- Find out if you transfer data internationally, and where to
- Put the appropriate safeguards in place

As well as protecting personal data within your own organisation, you also need to think about where else you send it to, and how well it is protected there. This is an involved area and could either be a long, protracted affair or a simple, timely one, depending on how well the requirements of the GDPR are understood. The first step is to know what data you send where, and why. You then have various options available to apply to the transfer, depending on factors such as the destination, type of data and the purpose. We provide a *Procedure for International Transfers of Personal Data* to help you to pick your way through this puzzle and understand what needs to be done.

4.9 STEP 9 - Personal data breach management

Relevant Toolkit documents

- *GDPR-DOC-09-1 Information Security Incident Response Procedure*
- *GDPR-DOC-09-2 Personal Data Breach Notification Procedure*
- *GDPR-DOC-09-3 Personal Data Breach Register*
- *GDPR-FORM-09-1 Personal Data Breach Notification Form*
- *GDPR-FORM-09-2 Breach Notification Letter to Data Subjects*
- *EXAMPLE Personal Data Breach Notification Form*

Key tasks

- Define how you will handle a personal data breach
- Test your procedures
- Start to notify where appropriate

The general consensus within the information security industry nowadays is not *if* an organisation will suffer a security breach, but *when*; and it may already have happened, but you just don't know about it. So, having an appropriate and tested incident management procedure is a must. The procedure in the Toolkit is a good starting point for incidents affecting not only personal data, but for a range of information security events, including denial of service attacks and ransomware.

The GDPR insists that your supervisory authority be told about known breaches that represent a risk to data subjects and is specific about the timescales and the information that must be provided. We provide a notification procedure, form and register in the Toolkit which should help to speed things up if the worst does happen. And if the breach is judged to potentially result in a high risk to the data

subjects, then you'll need to let them know, and the *Breach Notification Letter to Data Subjects* is a good starting point.

4.10 STEP 10 – Information Security Policies

Relevant Toolkit documents

- *GDPR-DOC-10-1 Information Security Policy*
- *GDPR-DOC-10-2 Mobile Device Policy*
- *GDPR-DOC-10-3 Access Control Policy*
- *GDPR-DOC-10-4 Cryptographic Policy*
- *GDPR-DOC-10-5 Physical Security Policy*
- *GDPR-DOC-10-6 Anti-Malware Policy*
- *GDPR-DOC-10-7 Network Security Policy*
- *GDPR-DOC-10-8 Electronic Messaging Policy*
- *GDPR-DOC-10-9 Cloud Computing Policy*
- *GDPR-DOC-10-10 Acceptable Use Policy*

Key tasks

- Define your information security policies
- Approve, publish and communicate the policies
- Ensure the policies are being complied with

The GDPR talks about providing appropriate safeguards for personal data, whether you're a controller or a processor or both. Once you've been through the process of understanding the personal data you're processing, it's time to start strengthening the controls you have in place to protect it. The set of policy documents in the Toolkit is a good starting point to achieve this. As you implement these policies you may find that you feel the need for a structured framework so that controls are based on risk, objectives are clearly defined, and improvement is at the core of everything you do; this is where the ISO27001 standard comes into its own and, in order to solidify your GDPR compliance, we would recommend that this is your next step.

5 Conclusion

This implementation guide has taken you through the process of positioning your organisation to achieve compliance to the GDPR, supported by the CertiKit GDPR Toolkit. Hopefully you will have seen that most of what's involved is applied common sense, even if the regulation doesn't always make it sound that way!

Implementing the requirements of a regulation such as the GDPR is always a culture change towards becoming more proactive as an organisation and, with the day to day reactive pressures of delivering a product or service, it can sometimes seem daunting. However, we hope you will find that the Toolkit is of value in clarifying what needs to be done and speeding up the process of compliance.

We wish you good luck in your work and, as always, we welcome any feedback you wish to give us via feedback@certikit.com.

6 Appendix A – List of Supervisory Authorities

Country	Supervisory Authority	Website
Austria	Österreichische Datenschutzbehörde	www.dsb.gv.at
Belgium	Commission de la protection de la vie privée	www.privacycommission.be
Bulgaria	Commission for Personal Data Protection	www.cdpd.bg
Croatia	Croatian Personal Data Protection Agency	www.azop.hr
Cyprus	Commissioner for Personal Data Protection	www.dataprotection.gov.cy
Czech Republic	The Office for Personal Data Protection	www.uoou.cz
Denmark	Datatilsynet	www.datatilsynet.dk
Estonia	Estonian Data Protection Inspectorate (Andmekaitse Inspektsioon)	www.aki.ee/en
Finland	Office of the Data Protection Ombudsman	www.tietosuoja.fi/en
France	Commission Nationale de l'Informatique et des Libertés - CNIL	www.cnil.fr
Germany	Die Bundesbeauftragte für den Datenschutz und die Informationsfreiheit	www.bfdi.bund.de
Greece	Hellenic Data Protection Authority	www.dpa.gr
Hungary	National Authority for Data Protection and Freedom of Information	www.naih.hu
Ireland	Data Protection Commissioner	www.dataprotection.ie
Italy	Garante per la protezione dei dati personali	www.garanteprivacy.it
Latvia	Data State Inspectorate	www.dvi.gov.lv
Lithuania	State Data Protection	www.ada.lt

Country	Supervisory Authority	Website
Luxembourg	Commission Nationale pour la Protection des Données	www.cnpd.lu
Malta	Office of the Data Protection Commissioner	www.dataprotection.gov.mt
Netherlands	Autoriteit Persoonsgegevens	www.autoriteitpersoonsgegevens.nl/nl
Poland	The Bureau of the Inspector General for the Protection of Personal Data - GIODO	www.giodo.gov.pl
Portugal	Comissão Nacional de Protecção de Dados - CNPD	www.cnpd.pt
Romania	The National Supervisory Authority for Personal Data Processing	www.dataprotection.ro
Slovakia	Office for Personal Data Protection of the Slovak Republic	www.dataprotection.gov.sk
Slovenia	Information Commissioner	www.ip-rs.si
Spain	Agencia de Protección de Datos	www.agpd.es/
Sweden	Datainspektionen	www.datainspektionen.se/
United Kingdom	The Information Commissioner's Office	www.ico.org.uk